

**ESCOLA
SUPERIOR
DE TECNOLOGIA
E GESTÃO**

P.PORTO

Criptografia Aplicada

Funções de Hash, Assinaturas Digitais, MACs, Derivações e Protocolos de Acordo de Chave

Funções de dispersão (Hash)

- Funções matemáticas (de dispersão) muito eficientes, capazes de mapear mensagens de qualquer tamanho em valores e tamanho fixo, denominados de valor de hash.
- Funções de Hash Criptográficas são funções de hash consideradas praticamente impossíveis de reverter, ou seja utilizando apenas o resultado da operação é muito difícil obter os dados originais.



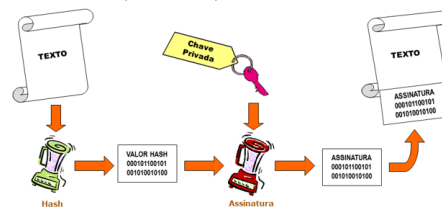
14/03/2025

GIH @ Criptografia Aplicada 2025.05

3

Assinatura Digital

Funcionamento (Assinatura)



14/03/2025

GIH @ Criptografia Aplicada 2025.05

11

MAC (Message Authentication Codes)

MAC - Message Authentication Codes

- Informação (de tamanho reduzido) utilizada para autenticar uma mensagem
- Serve para:
 - Confirmar que a mensagem vem do emissor
 - Confirmar que a mensagem não foi alterada
- Assim o MAC permite proteger a integridade e autenticidade de uma mensagem de qualquer tamanho, mapeando-a em valores de tamanho fixo denominados de MAC (ou tag)

14/03/2025

GIH @ Criptografia Aplicada 2025.05

17

Protocolos de Acordo de Chave

• Necessidade

- Para que dois ou mais intervenientes possam comunicar de forma segura entre si, necessitam de partilhar a mesma chave secreta
- Dada a dificuldade em a distribuir de forma off-wire, existem técnicas que permitem que a mesma seja acordada entre as partes...
 - Em tempo real
 - De acordo com um processo que não permita a um atacante que escute a comunicação descobrir a chave acordada entre as partes
- Exemplos: Diffie-Hellman, El Gamal, MTI, Station to Station, etc.
- Para que não sejam vulneráveis a ataques man-in-the-middle, o protocolo utilizado necessita de assegurar a identificação inequívoca de (pelo menos) um dos agentes

20/03/2026

GIH @ Criptografia Aplicada 2026.05

33

Assinaturas Digitais – Teórico-Prática

• Teórico-Prática

- Exercício de Assinaturas digitais em Java
 - Java 8 (ou superior // last update)
 - Eclipse ou
 - Netbeans

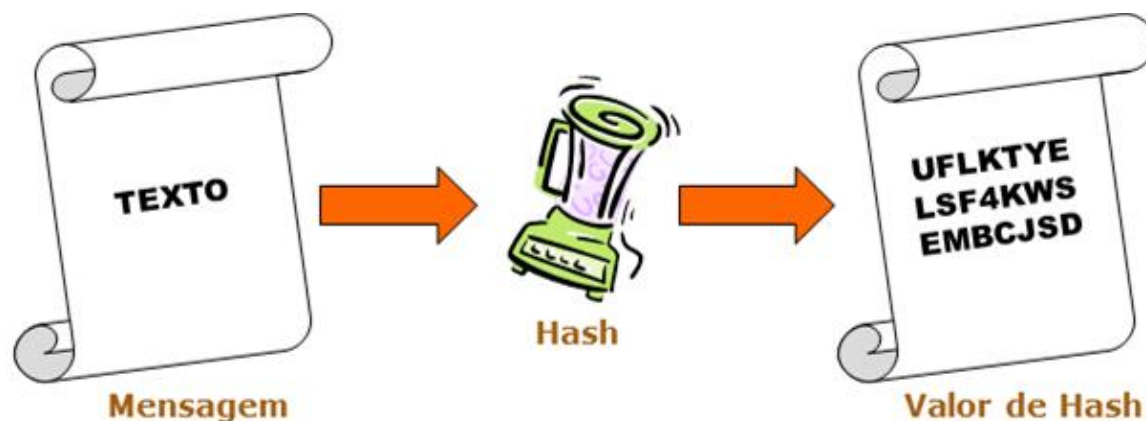
20/03/2026

GIH @ Criptografia Aplicada 2026.05

47

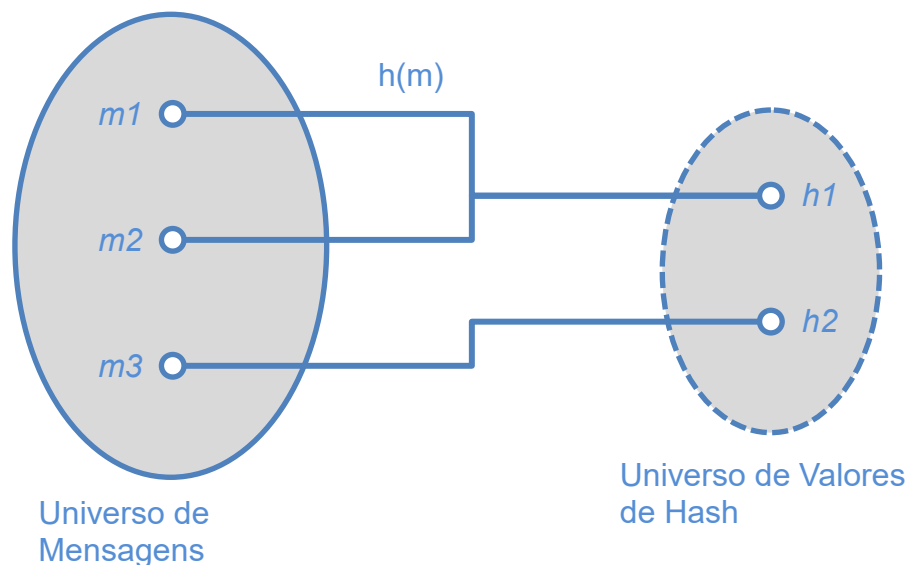
Funções de dispersão (Hash)

- Funções matemáticas (de **dispersão**) muito eficientes, capazes de **mapear mensagens de qualquer tamanho** em valores e **tamanho fixo**, denominados de **valor de hash**.
- Funções de **Hash Criptográficas** são funções de **hash** consideradas **praticamente impossíveis de reverter**, ou seja utilizando apenas o **resultado da operações** é muito difícil obter os **dados originais**.



Funções de dispersão (Hash)

- Dado que o número de resultados possíveis é finito e usualmente inferior ao universo das mensagens originais, teoricamente podem existir colisões



Funções de dispersão (Hash)

- Para que sejam seguras necessitam ...
 - Que seja **fácil de calcular** o valor de **dispersão** de uma mensagem
 - Ser **unidirecionais**, **impedindo** a **recuperação** da mensagem original a partir do valor de hash
 - Ser **fortemente livres de colisões**, dispersando os valores de hash pelo universo de resultados possíveis, **garantindo que é computacionalmente intratável** encontrar **duas mensagens** com o **mesmo** valor de **hash**
 - Entende-se que algo é **computacionalmente intratável** caso **não possa ser concretizado** mesmo utilizando **todos os recursos computacionais existentes** no planeta

Funções de dispersão (Hash)

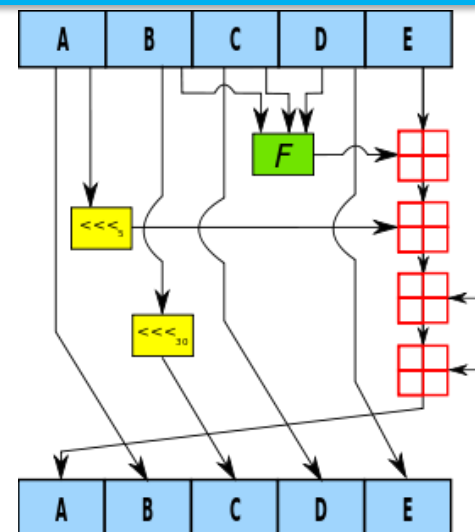
- Algoritmos mais populares
 - MD5
 - Publicado em 1992 pela RSA (empresa)
 - Produz um valor de hash de 16 bytes (128 bits)
 - Desde 1996 que a sua utilização é altamente desaconselhada, dado terem sido descobertas vulnerabilidades de segurança graves, que permitem encontrar facilmente duas mensagens com o mesmo valor de hash

Funções de dispersão (Hash)

- Algoritmos mais populares

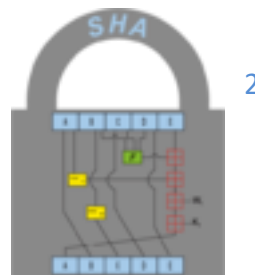
- SHA-1

- Publicado em 1995 pelo NIST
- Produz um valor de hash de 20 bytes (160 bits)
- Apesar de ainda bastante popular, a sua utilização é desaconselhada dado terem sido descobertas vulnerabilidades¹ e demonstrações de técnicas que tornam possível e computacionalmente tratável a procura de duas mensagens distintas com o mesmo valor de hash



1 - <http://shattered.io/>

2 - <http://www.sha1-online.com/>

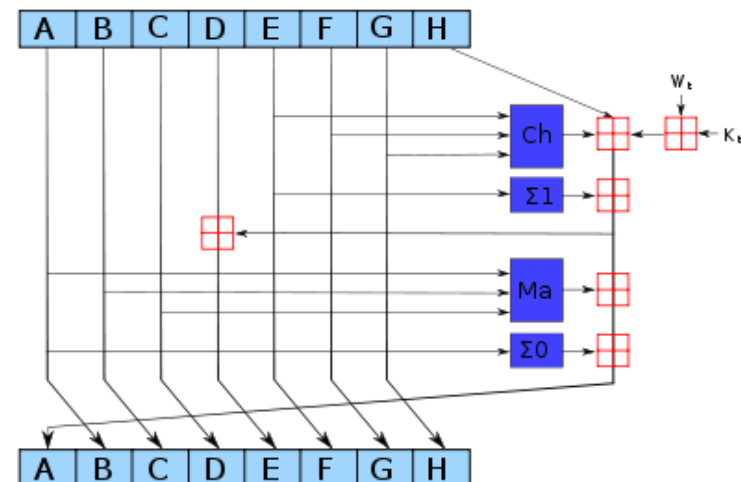


Funções de dispersão (Hash)

- Algoritmos mais populares

- SHA-2

- Publicados em 2002 pelo NIST
- Produzem um valor de hash de 224 bits (28 bytes), 256 bits (32 bytes), 384 bits (48 bytes) e 512 bits (64 bytes), respetivamente

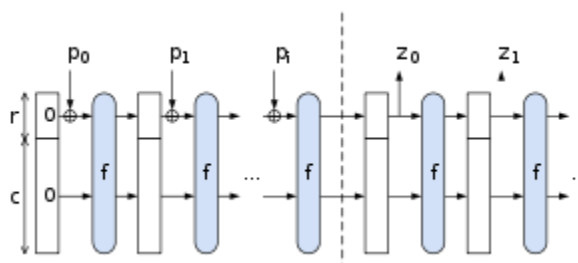


Funções de dispersão (Hash)

- Algoritmos mais populares

- SHA-3

- Concurso proposto pelo NIST, publicado em 5 de Agosto de 2015
- Baseado no algoritmo Keccak
- Tamanhos de 224, 256, 384 e 512 bits (28, 32, 48 e 64 bytes respetivamente)

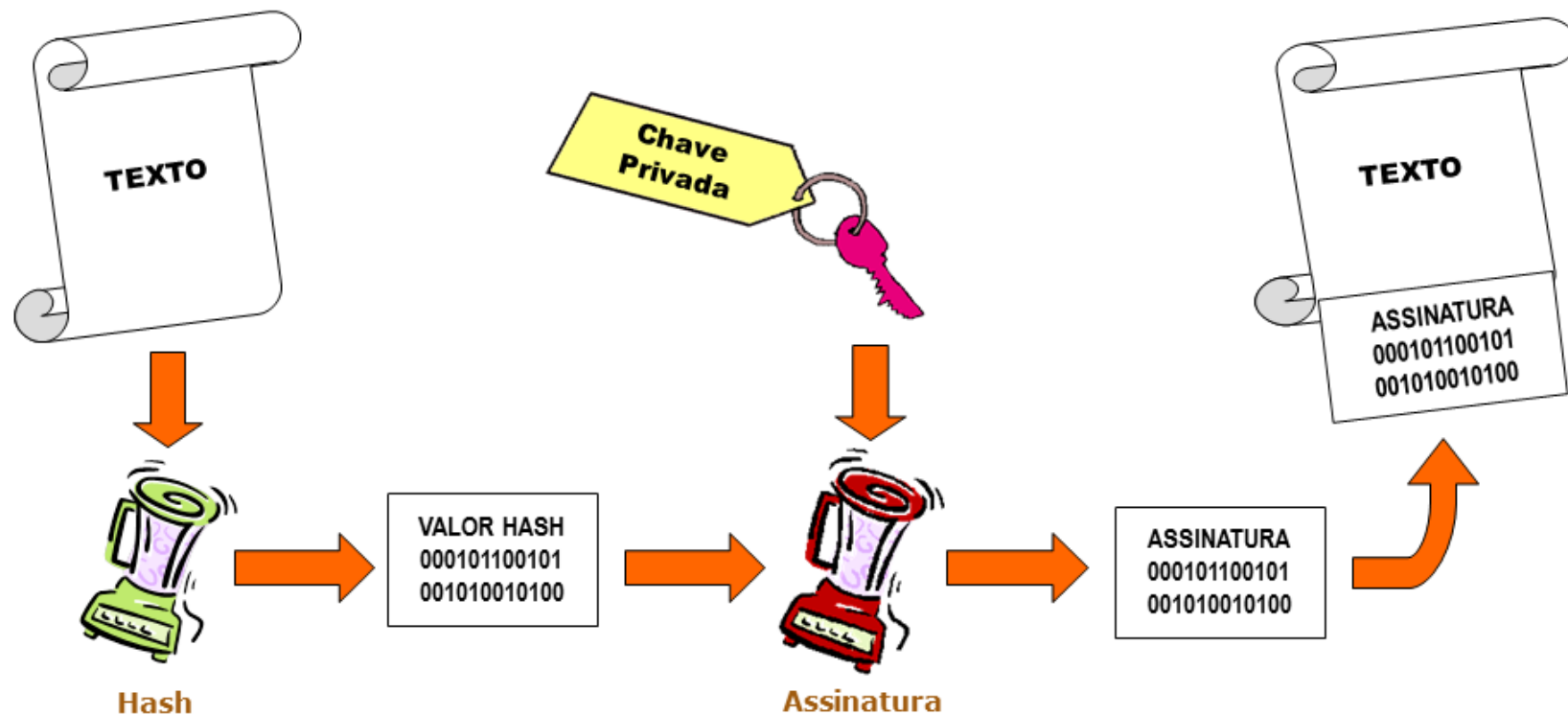


Funções de dispersão (Hash)

Questões?

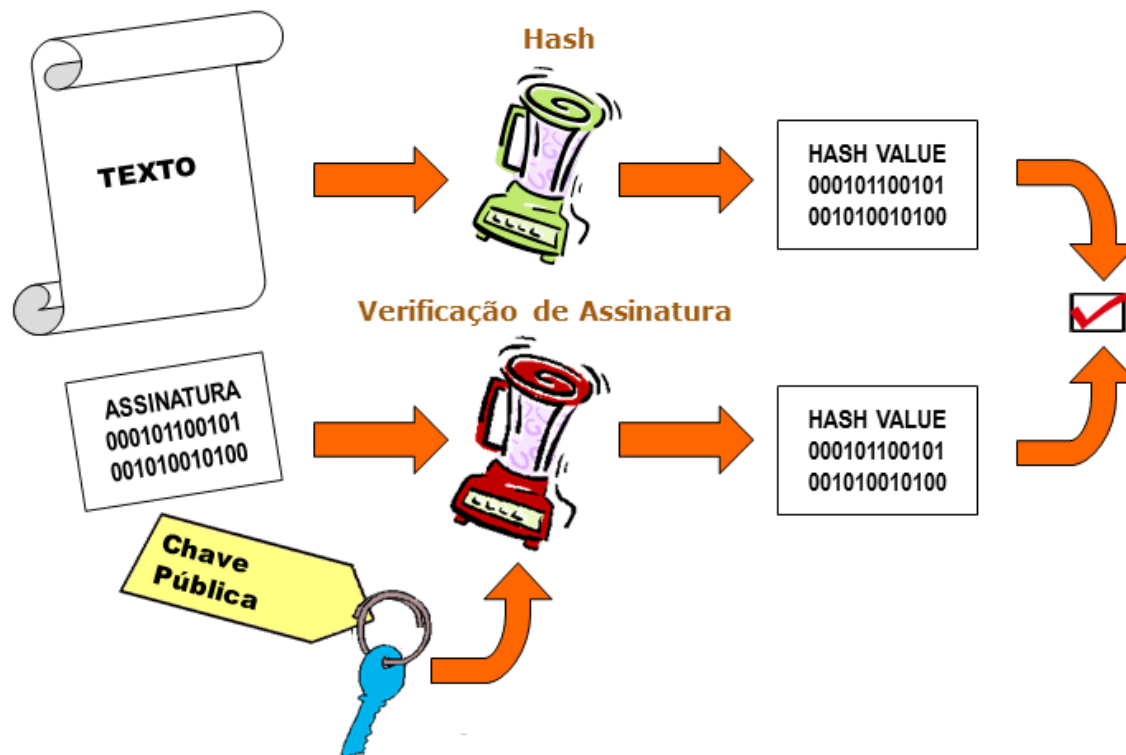
Assinatura Digital

Funcionamento (Assinatura)



Assinatura Digital

Funcionamento (Verificação)



Assinatura Digital

Funcionamento (Assinatura RSA)

Chave Pública	(m, a)
Chave Privada	(m, b)

- Assinatura

Dada uma mensagem x , uma assinatura RSA y define-se como:

$$y = x^b \pmod{m}$$

- Verificação da Assinatura

Dada uma mensagem x e uma assinatura RSA y , é necessário verificar se:

$$x = y^a \pmod{m}$$

Assinatura Digital

Funcionamento (Assinatura El Gamal)

Chave Pública (p, b, r)

Chave Privada (e)

- Assinatura

- Seleciona-se um valor u aleatório, tal que $u \in \mathbb{Z}_{p-1}^*$ $u \in \mathbb{Z}_{p-1}$
- Calcula-se o valor $w = b^u \pmod{p}$
- Dada uma mensagem $0 < x < (p - 1)$, uma assinatura El Gamal define-se como o par (s, w)

em que s é a solução de $(u * s) + (e * w) = x \pmod{p - 1}$

- Verificação da Assinatura

Dada uma mensagem x e uma assinatura El Gamal (s, w) , é necessário verificar se:

$$w^s * r^w = b^x \pmod{p}$$

Assinatura Digital

Esquema de assinatura DSA

- DSA - (Digital Signature Algorithm)
 - Definido em 1994 como uma norma FIPS
 - Apesar de ser inspirado no El Gamal, é mais eficiente e carece de menos recursos para gerar e representar as assinaturas, o que potencia a sua utilização em equipamentos com menor memória e capacidade de computação
 - Contudo, o processo de verificação de assinatura não é tão eficiente quanto o processo de geração da mesma
 - Compõe o DSS (Digital Signature Standard), juntamente com:
 - O algoritmo de hash SHA (1 ou 2)
 - Funções auxiliares (incluindo a geração de números aleatórios)
 - É vulnerável ao mesmo tipo de ataques que o El Gamal

Assinatura Digital

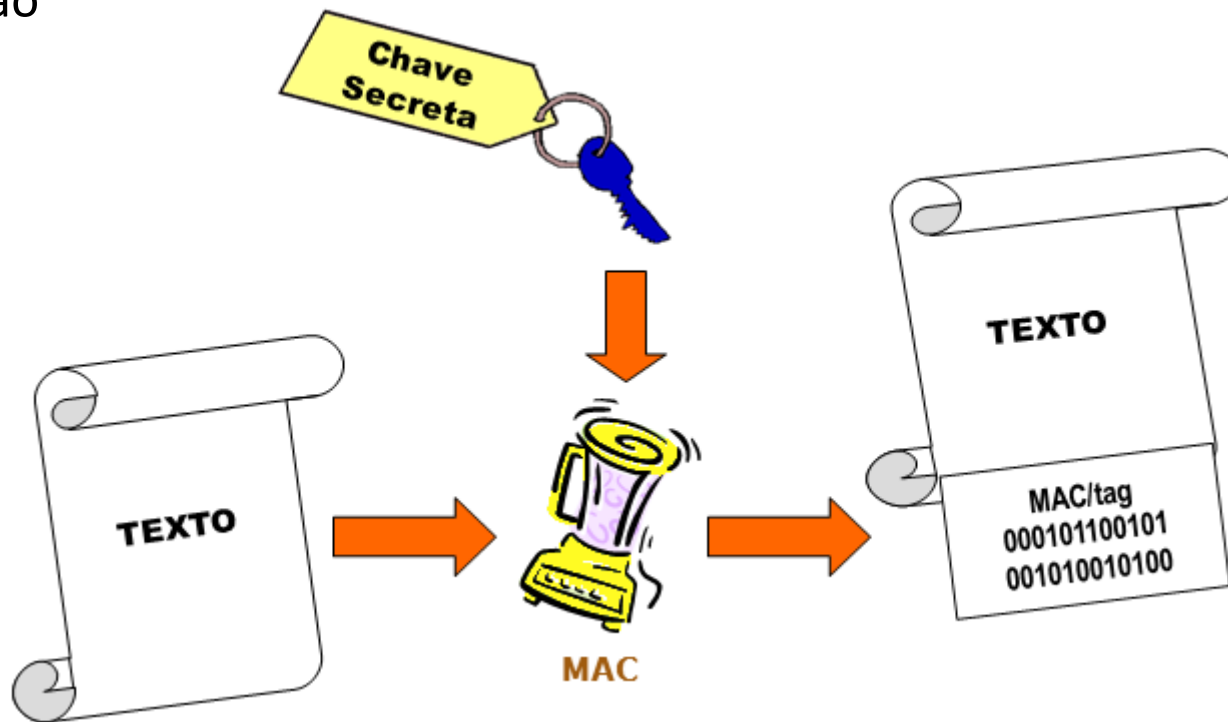
Questões?

MAC (Message Authentication Codes)

- MAC - Message Authentication Codes
 - Informação (de tamanho reduzido) utilizada para autenticar uma mensagem
 - Serve para:
 - Confirmar que a mensagem vem do emissor
 - Confirmar que a mensagem não foi alterada
 - Assim o MAC permite proteger a integridade e autenticidade de uma mensagem de qualquer tamanho, mapeando-a em valores de tamanho fixo denominados de MAC (ou tag)

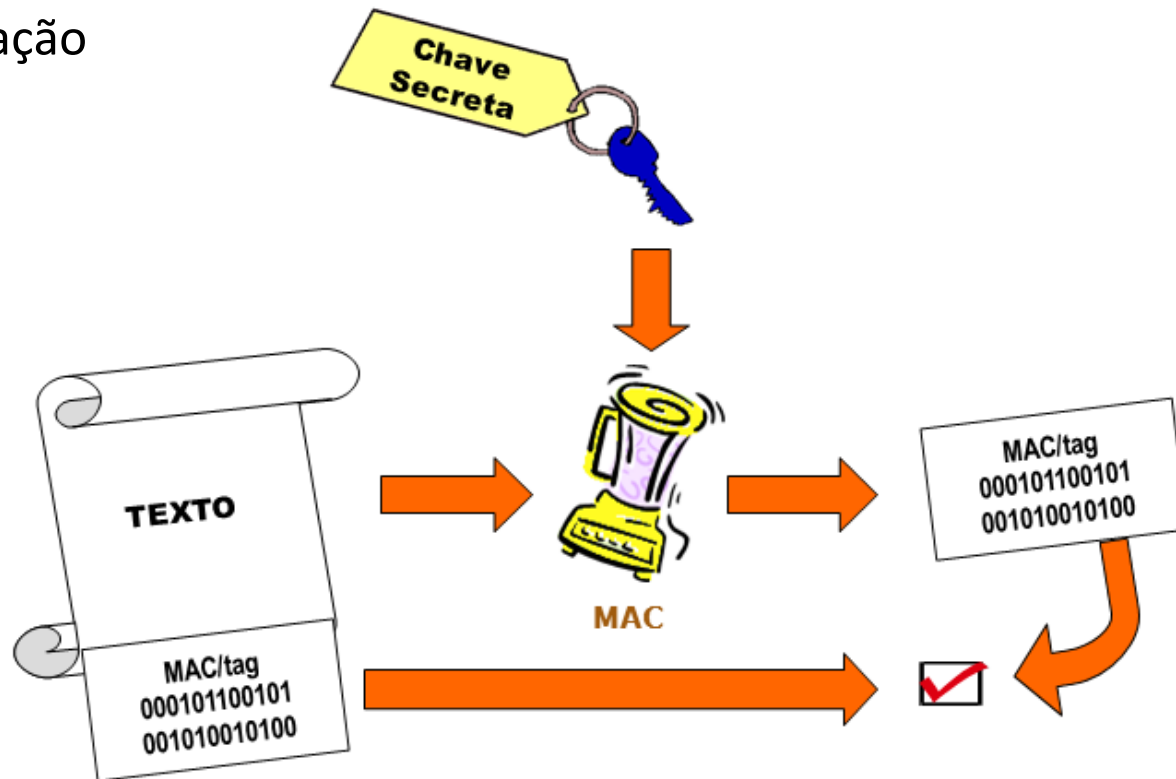
MAC (Message Authentication Codes)

- MAC - Message Authentication Codes
 - Criação



MAC (Message Authentication Codes)

- MAC - Message Authentication Codes
 - Verificação



MAC (Message Authentication Codes)

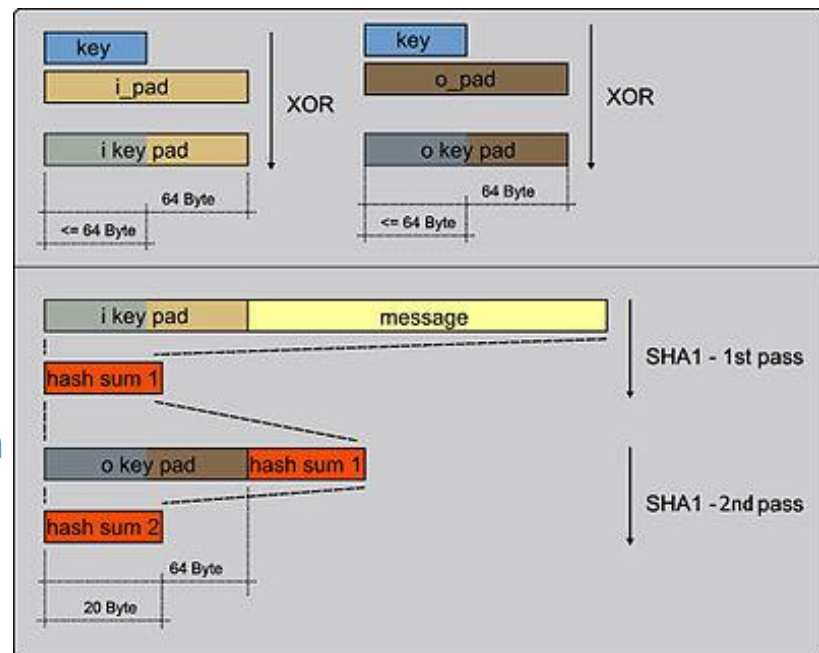
- MAC - Message Authentication Codes
 - Difere de uma função de hash dado que...
 - Também dependem de uma chave simétrica, o que lhes permite assegurar a autenticidade da mensagem (que um atacante não pode alterar porque desconhece a chave)
 - Difere de uma função de assinatura dado que...
 - Não utiliza uma chave assimétrica
 - Não permite assegurar o não repúdio, dado que o destinatário também pode criar MACs (e não apenas verificá-los)
 - Para que sejam considerados seguros, necessitam de garantir que, mesmo que um atacante consiga convencer o emissor a calcular um MAC sobre uma determinada mensagem, isso não lhe permitiria calcular o MAC de uma outra qualquer mensagem

MAC (Message Authentication Codes)

- MAC - Message Authentication Codes - Propriedades
 - Cryptographic Checksum – Um MAC gera uma Tag de autenticação segura para uma dada mensagem
 - Baseiam-se em chaves simétricas – chave tem que ser partilhada entre quem assina e quem verifica
 - MACs funcionam com mensagens de tamanho variável
 - Tamanho fixo – Os MACs têm tamanho fixo
 - Integridade da mensagem – qualquer manipulação da mensagem pode ser detetada
 - Autenticação da mensagem – o recetor fica com conhecimento da origem da mensagem

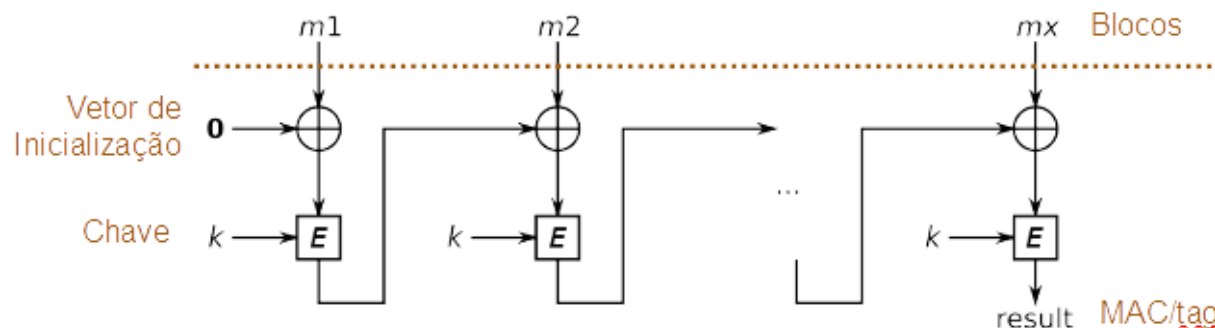
MAC (Message Authentication Codes)

- Algoritmos mais populares
 - HMAC (Hash-based Message Authentication Code)
 - Publicado em 1997 no RFC 2104
 - Baseado na utilização de uma função de hash (à escolha), devido à sua maior eficiência (quando comparada com uma cifra simétrica)
 - Produz um resultado do mesmo tamanho do algoritmo de hash utilizado, sendo atualmente recomendado o SHA-2
 - Utilizado nos protocolos TCP/IP e SSL/TLS



MAC (Message Authentication Codes)

- Algoritmos mais populares
 - CBC-MAC (Cipher Block Chaining Message Authentication Code)
 - Implementa um código de autenticação de mensagem a partir de uma cifra por blocos
 - Permite utilizar um qualquer algoritmo de cifra no modo CBC, considerando o vetor de inicialização com o valor 0
 - A sua utilização não é considerada segura para mensagens de tamanho variável



MAC (Message Authentication Codes)

- Algoritmos mais populares
 - CMAC (Cipher-based Message Authentication Code)
 - Otimização do CBC-MAC, com o objetivo de colmatar as suas vulnerabilidades em mensagens de tamanho variável
 - Ao contrário do CBC-MAC, a chave utilizada para cifrar os vários blocos não é sempre a mesma, sendo em vez disso utilizada para efetuar a derivação de duas sub-chaves
 - Compatível com a utilização do TripleDES e AES

MAC (Message Authentication Codes)

Questões?

Derivações de Chave

- Necessidade

- Podemos utilizar uma password como chave criptográfica?
- Dificuldades:
 - Tamanho desadequado para os algoritmos
 - Vulnerável a ataques por dicionário
 - Pouca entropia ou aleatoriedade
 - Como obter múltiplas chaves derivadas?
- Motivação:
 - Transformar segredos fracos (passwords) em chaves criptográficas fortes
 - Objetivo: resistir a brute force e ataques com GPUs

Derivações de Chave

- Definição

- Uma Função de Derivação de Chave (KDF - *Key Derivation Function*) é uma função criptográfica que:
 1. Recebe segredo inicial (Input Key Material: Password, Masterkey, SecretKey, ...)
 2. Pode utilizar/adicionar salt (ou contexto – valor aleatório)
 3. Pode implementar múltiplas iterações (custo computacional)
 4. Produz uma ou mais chaves seguras (tamanho da chave)



Derivações de Chave

- Salt

- Valor aleatório e único, utilizado para:
 - Introduce aleatoriedade e permite evitar *rainbow tables*
 - Garante que passwords iguais produzem chaves diferentes
 - Guarda-se juntamente com a chave criptográfica (resultado do KDF)

- Iterações

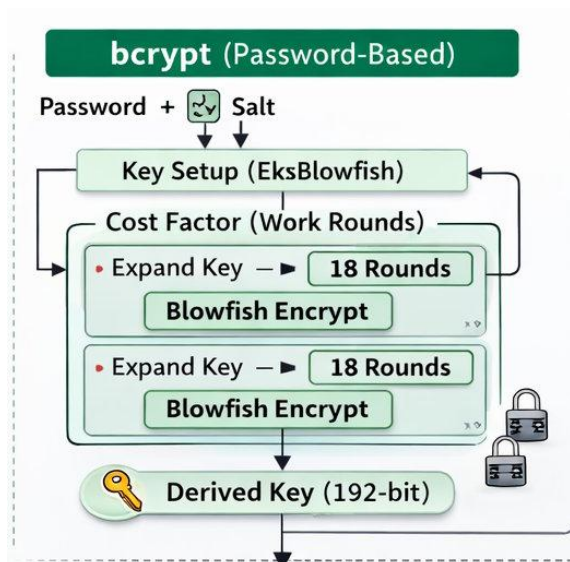
- Aplicação da função múltiplas vezes
 - Dificulta o ataque
 - Tempo (mais lento)
 - Custo (mais caro computacionalmente)
 - » $\text{hash}(\text{hash}(\text{hash}(\text{hash}(\text{hash}(\text{password})))$
 - Recomendam-se valores elevados (500,000+)



Derivações de Chave

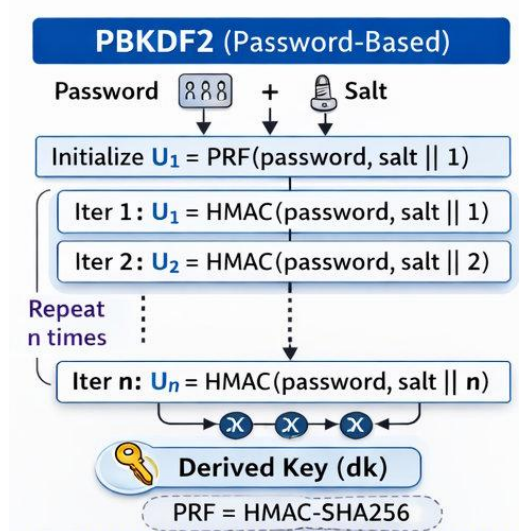
- **bcrypt**

- Muito adaptável e resistente a ataques modernos



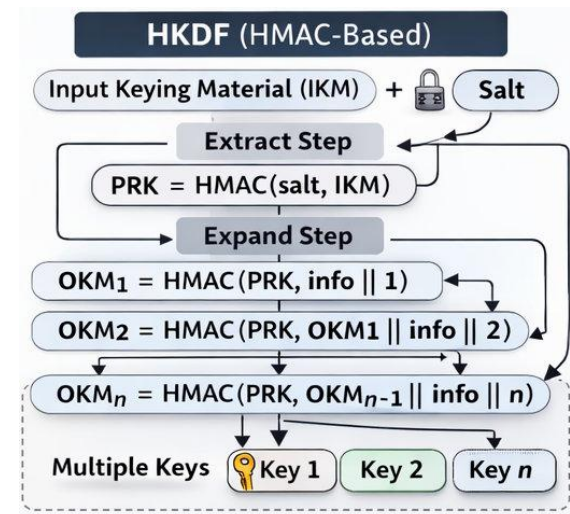
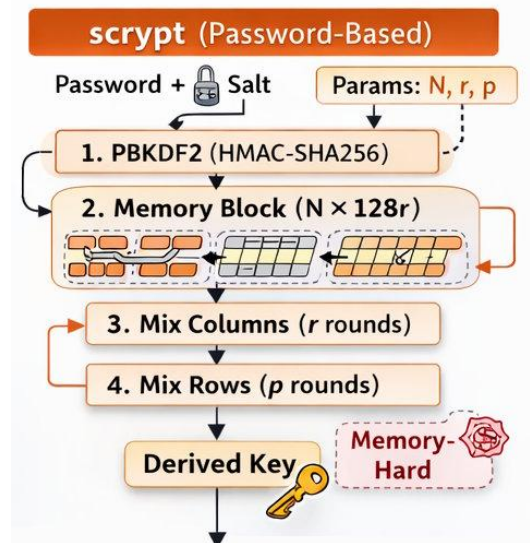
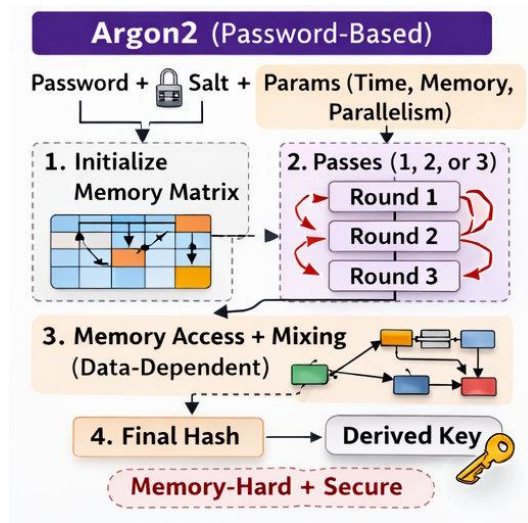
- **PBKDF2**

- Muito utilizado para armazenamento de password e alongamento de chaves



Derivações de Chave

- Argon2
 - Vencedor do concurso de Password Hashing
- Scrypt
 - Requer elevados recursos de memória e assim protege contra aceleração por hardware
- HKDF
 - Utilizado em muitos protocolos modernos (TLS)



Derivações de Chave

- Boas práticas
 - Usar salt aleatório
 - Usar muitas iterações
 - Preferir KDFs modernas como Argon2 ou Scrypt
- Protocolos como TLS usam KDFs para gerar várias chaves:
 - Encryption key
 - MAC key
 - IV

Derivações de Chave

Questões ?

Protocolos de Acordo de Chave

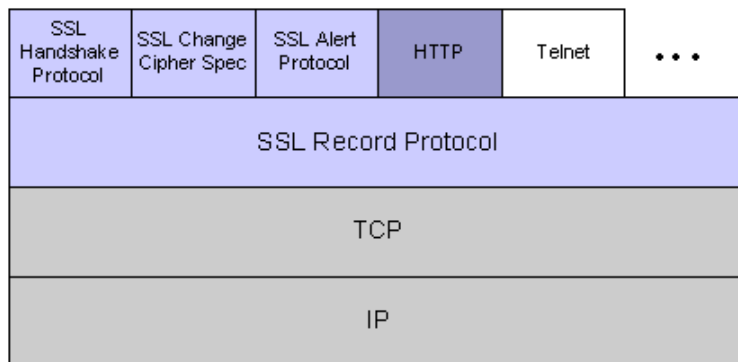
- Necessidade

- Para que **dois ou mais intervenientes** possam comunicar de forma **segura entre si**, necessitam de **partilhar a mesma chave secreta**
- Dada a **dificuldade** em a **distribuir** de forma *off-wire*, existem **técnicas** que permitem que a mesma seja **acordada entre as partes...**
 - Em **tempo real**
 - De acordo com um **processo** que **não permita** a um **atacante** que **escute a comunicação** descobrir a **chave acordada** entre as partes
- Exemplos: **Diffie-Hellman, El Gamal, MTI, Station to Station**, etc.
- Para que **não sejam vulneráveis** a ataques *man-in-the-middle*, o **protocolo** utilizado necessita de **assegurar a identificação inequívoca** de (pelo menos) **um dos agentes**

Protocolos de Acordo de Chave

- SSL

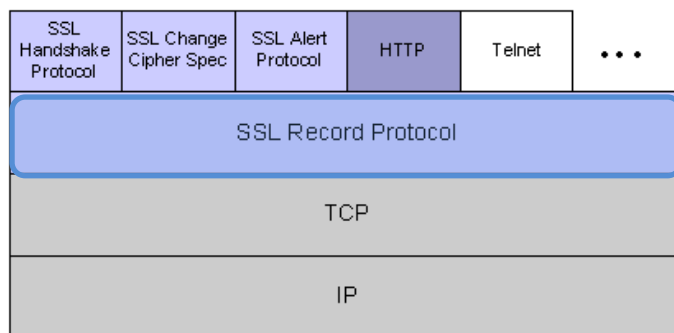
- Originalmente publicado pela Netscape em 1995
- Standard *de facto* na Web - Permite assegurar a autenticação, integridade e confidencialidade de uma ligação entre um cliente e um servidor
- Define quatro protocolos, distribuídos por duas camadas...
- A deteção de algumas vulnerabilidades levaram à publicação da versão 3.0 em 1996



Protocolos de Acordo de Chave

- SSL – Protocolo de Registo

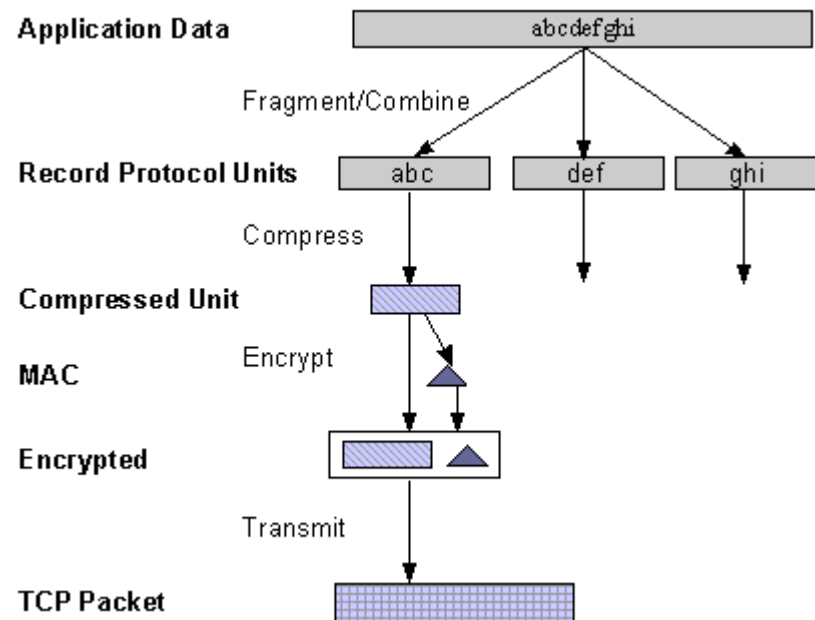
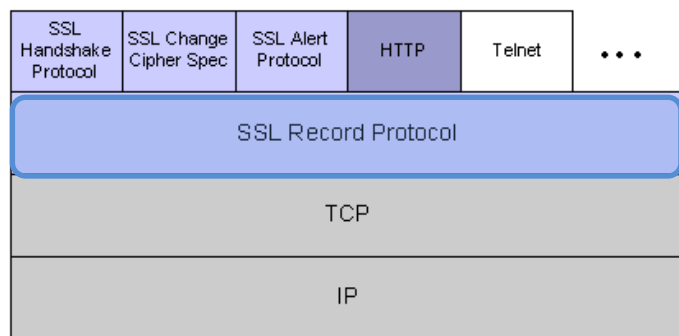
- Protocolo base, oferece aos protocolos superiores serviços de...
 - Fragmentação e compactação de dados
 - Confidencialidade
 - Cifrando o conteúdo das mensagens com uma chave secreta
 - Integridade
 - Autenticando o conteúdo das mensagens com MACs calculados usando uma chave secreta



Protocolos de Acordo de Chave

- SSL – Protocolo de Registo

- A **chave secreta** utilizada na **cifra/MAC** é **acordada** entre **cliente e servidor** através do **protocolo de estabelecimento de sessão**

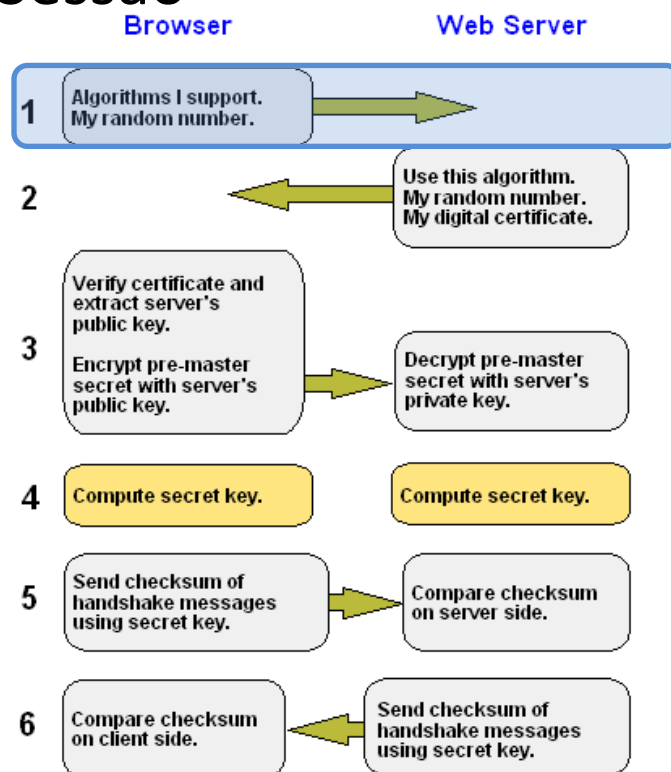
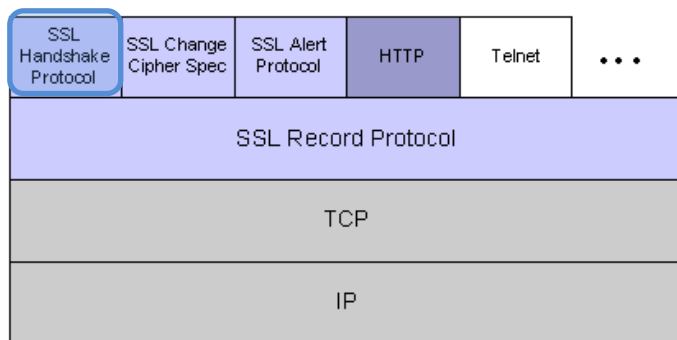


Protocolos de Acordo de Chave

- SSL – Protocolo de Estabelecimento de Sessão

- Fase 1 – Pedido de Comunicação Segura

- Cliente identifica a **versão do protocolo** e **algoritmos** de acordo de chaves, **cifra** e **compressão** que **suporta**, juntamente com o seu **número aleatório**

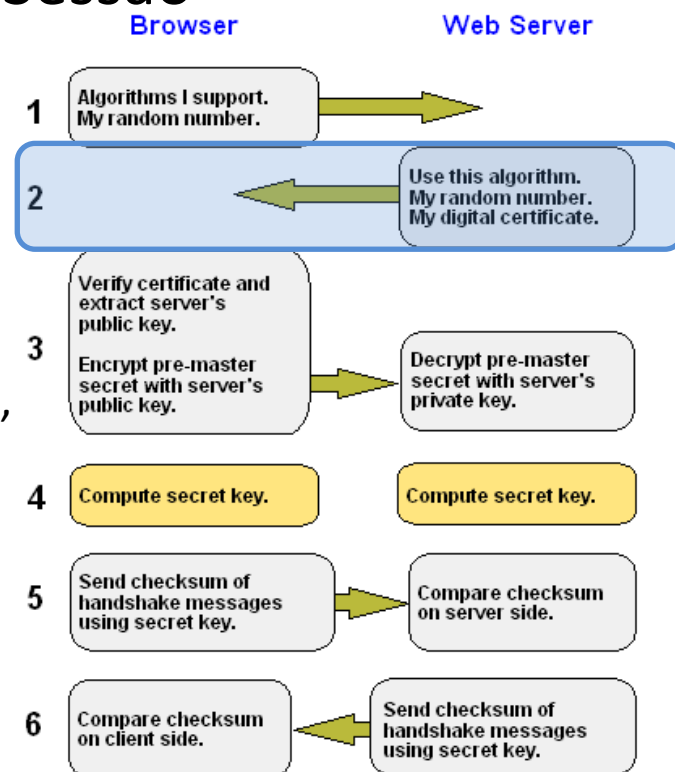


Protocolos de Acordo de Chave

- SSL – Protocolo de Estabelecimento de Sessão

- Fase 2 – Autenticação do Servidor

- Baseado nas capacidades do cliente, servidor devolve resposta identificando quais os algoritmos a utilizar, bem como o seu número aleatório
 - Servidor envia a sua identificação (certificado) e, se assim configurado, solicita ao cliente que apresente também a sua.

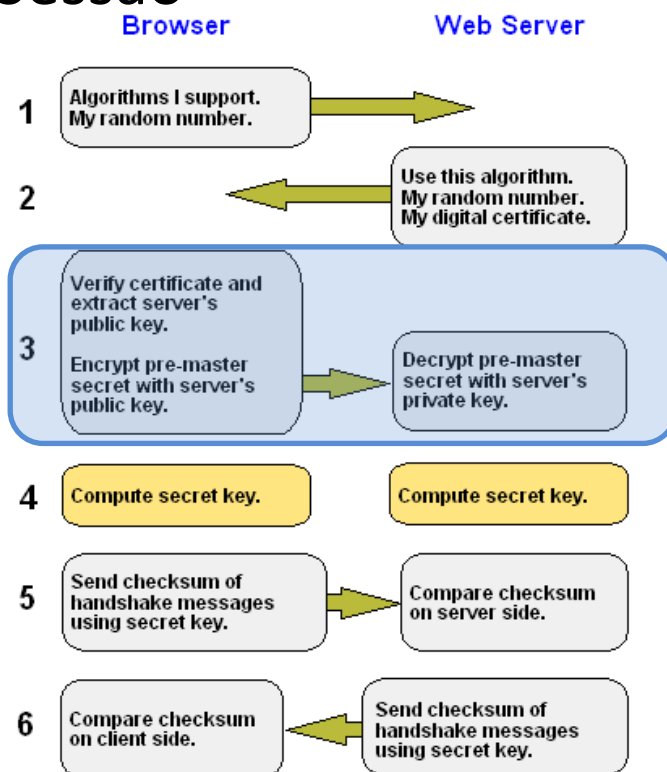


Protocolos de Acordo de Chave

- SSL – Protocolo de Estabelecimento de Sessão

- Fase 3 – Autenticação do Cliente

- Cliente verifica **identidade do servidor** (certificado) e obtém a sua **chave pública**
- Cliente gera um **pré-segredo mestre**, cifra-o com a chave pública do **servidor** e **envia-o para este**
- Servidor **decifra** o criptograma e recupera o **pré-segredo mestre**

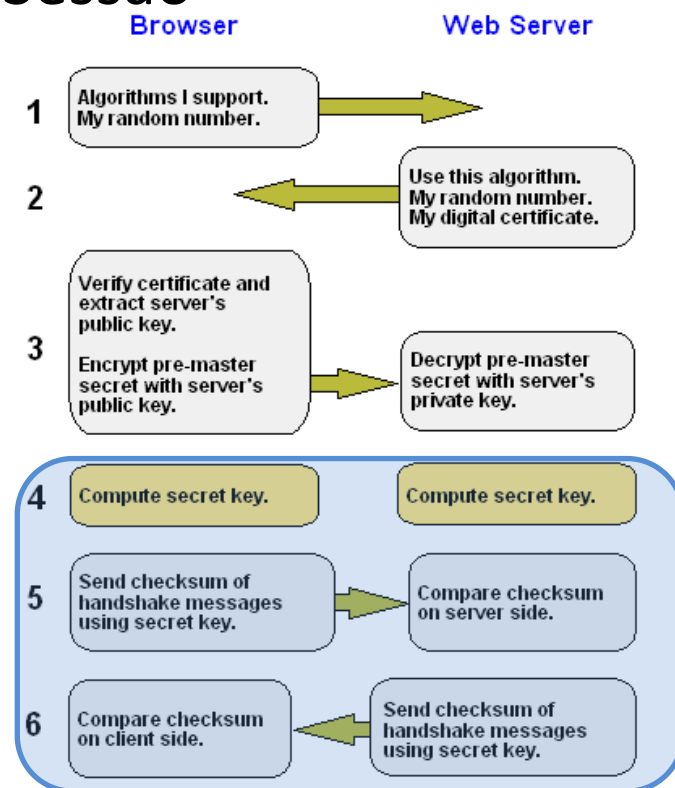


Protocolos de Acordo de Chave

- SSL – Protocolo de Estabelecimento de Sessão

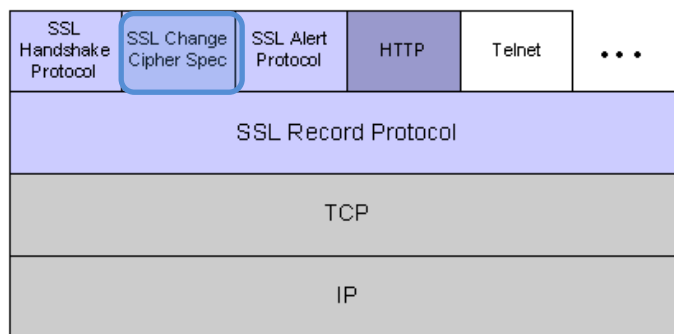
- Fase 4, 5 e 6 – Conclusão

- 4 - Cliente e servidor **calculam a chave secreta**, cujo valor depende do **pré-segredo mestre** e de **ambos os números aleatórios** gerados na fase 1
 - 5 – Cliente e servidor usam **chave secreta** para gerar um **MAC** sobre **todas as mensagens trocadas** até ao momento
 - 6 - Caso **verificações de MACs** sejam bem **sucedidas**, inicia-se a **comunicação cifrada**



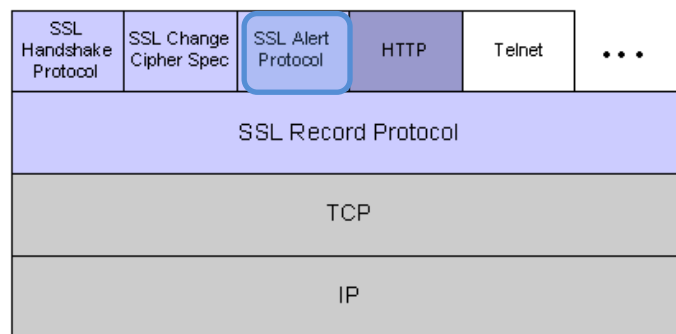
Protocolos de Acordo de Chave

- SSL – Protocolo de Mudança de Especificação de Cifra
 - Utilizado na **fase 6** do protocolo de estabelecimento de sessão, com o objetivo de comunicar que se deve **dar início à encriptação da comunicação** de acordo com os parâmetros acordados anteriormente
 - Composto por **uma única mensagem** que consiste em apenas um **byte** com o **valor 1**



Protocolos de Acordo de Chave

- SSL – Protocolo de Alerta
 - Permite transmitir mensagens de aviso ou erro relacionadas com a comunicação em curso (falha no acordo da cifra a utilizar, erro na interpretação da mensagem, certificado revogado, etc.)
 - Em caso de erro, a conexão é imediatamente encerrada



Protocolos de Acordo de Chave

- TLS – Transport Layer Security

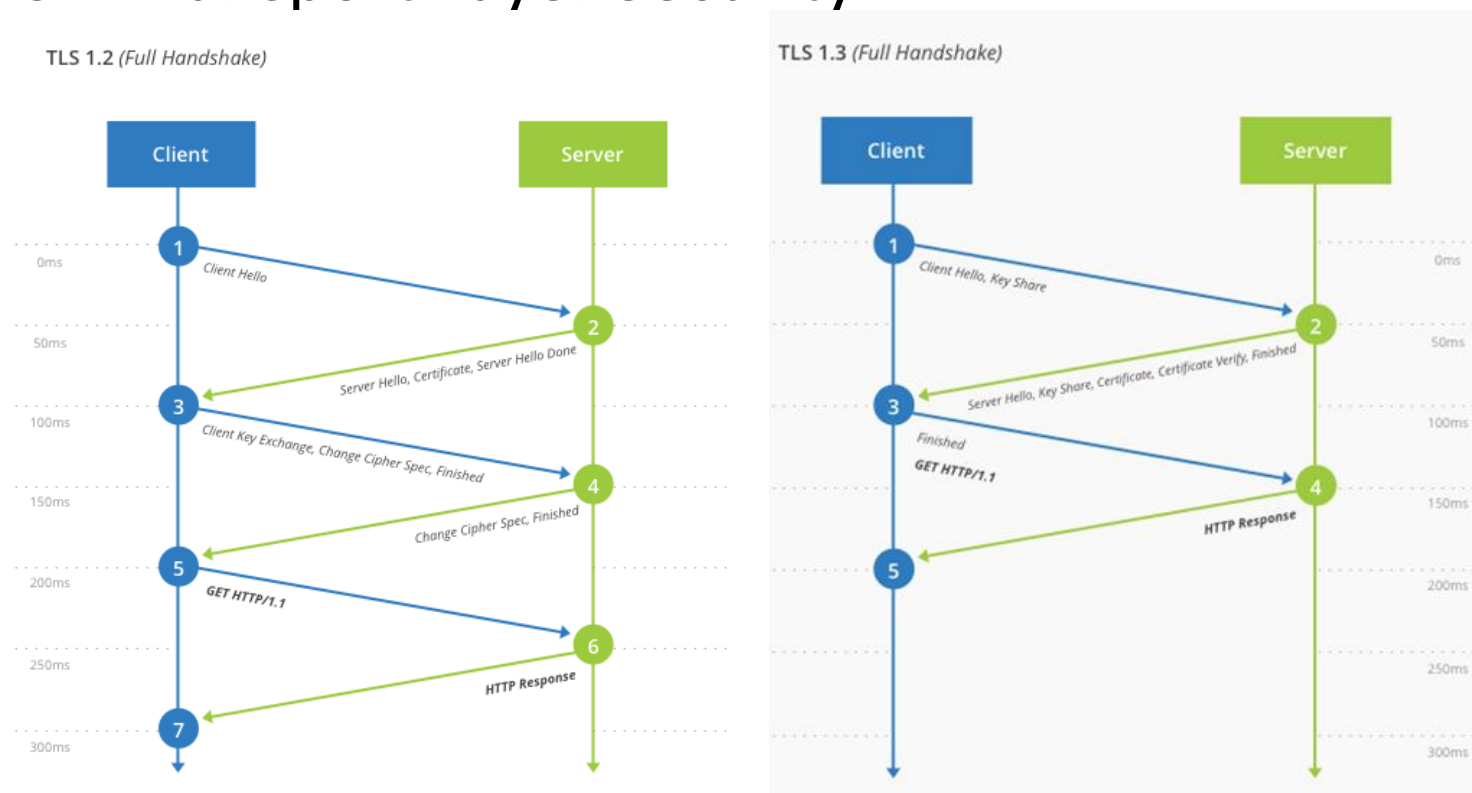
- Definido em 1999, evoluiu até à [versão 1.3 \(RFC8446 agosto de 2018\)](#) ([1.2 de 2008](#))
- As [diferenças](#) em relação ao SSL v3 não são muitas mas são [suficientes para que não sejam interoperáveis](#)
- Contudo, o TLS inclui um [mecanismo](#) que [permite reduzir o nível de segurança da ligação para SSL v3](#)
- As principais diferenças em relação ao SSL v3 passam por...
 - Falta de suporte para algoritmos de acordo de chaves e cifra Fortezza
 - Fórmula/algoritmos de cálculo dos MACs, quer de cada mensagem individual quer das mensagens de estabelecimento de sessão
 - Fórmula/algoritmos de cálculo da chave secreta

Protocolos de Acordo de Chave

- TLS – Transport Layer Security
 - Diferenças entre v1.2 e v1.3
 - Menos uma “Round-Trip” (Send/Receive) no “Handshake”
 - Atualização do protocolo HTTP/2
 - Conexões cifradas são mais rápidas
 - Remoção de suporte a determinados algoritmos:
 - MD5
 - SHA-1
 - RC4
 - DES
 - 3DES
 - AES-CBC

Protocolos de Acordo de Chave

- TLS – Transport Layer Security



Protocolos de Acordo de Chave

- [Vulnerabilidades TLS](#)

Questões?

Assinaturas Digitais – Teórico-Prática

- Teórico-Prática
 - Exercício de Assinaturas digitais em Java
 - Java 8 (ou superior // last update)
 - Eclipse ou
 - Netbeans

Assinaturas Digitais – Teórico-Prática

- Exercício de Assinatura Digital em Java
 - Criar classe que permita:
 - Gerar chaves (via: `java.security. ...`)
 - `KeyPairGenerator`, `KeyPair`, `PublicKey`, `PrivateKey`
 - Assinar digitalmente e validar assinatura
 - (Objeto) `Signature`
 - Gravar para ficheiro a chave pública
 - Ler a chave pública de ficheiro